Seguridad M4 y permisos

Version 1.0 | feature/terreno-agenda-visitas | d0735003f88a6b6a5d540049866bd74a680c2e04

2026-10-19 14:31 Hora verano Sudamérica Pacífico

DOCUMENTACION TECNICA Y PEDAGOGICA

Proyecto: Puertas Blindadas Documento: 15 Version: 1.0 Fecha de corte: 2026-10-19 14:31 Hora verano Sudamérica Pacífico
Rama: `feature/terreno-agenda-visitas` SHA documentado: `d0735003f88a6b6a5d540049866bd74a680c2e04`

> Alcance de evidencia: este manual describe el codigo, schema Prisma, migraciones, pruebas y documentacion presentes en el SHA indicado. Cuando una capacidad no puede demostrarse desde esas fuentes se marca como NO CONFIRMADO EN EL REPOSITORIO. Implementado, preparado, bloqueado, legacy y pendiente son estados distintos.

Tabla de contenidos

Tabla de contenidos 2
Como leer este documento 3
Modelo M4 3
Conceptos 3
Como diagnosticar un 403 3
Por que un usuario no ve algo 3
Regla de Midas 3
Fuentes de verdad consultadas 3

Como leer este documento

- Comportamiento actual significa que existe codigo operativo y evidencia verificable.
- Preparado significa que existen contratos, modelos o interfaz, pero falta una dependencia o activacion.
- Bloqueado significa que el sistema impide deliberadamente la operacion por seguridad o falta de autorizacion.
- Pendiente significa que no existe una implementacion completa demostrable.
- Las rutas de archivos se expresan desde `CODIGO/`.

Modelo M4

M4 combina autenticacion, sesion, perfil, permisos de perfil, permisos particulares, dependencias administrativas y alcance operacional. React puede ocultar acciones, pero el backend decide.

Conceptos

- `administrador`: capacidad administrativa efectiva de la sesion/cuenta.
- `administrador_original`: marca protegida de la cuenta raiz; debe conservar CU administrativos aprobados.
- `configuracion_particular`: usa asignaciones particulares registradas; no debe reducir accidentalmente a Midas.
- `alcanceEmpleadoId`: limita operaciones a un empleado cuando el CU no concede gestion general.
- Midas: recibe todos los CU activos aprobados, excepto CU377 mientras siga bloqueado. No es un bypass.

Como diagnosticar un 403

1. Confirmar sesion vigente y cuenta correcta.
2. Identificar CU exigido por endpoint.
3. Consultar permisos efectivos, no solo perfil visual.
4. Revisar `requiere_administrador` y `administrador_original`.
5. Revisar configuracion particular y dependencias.
6. Revisar alcance por empleado/entidad.
7. Confirmar estado de la entidad.

Por que un usuario no ve algo

Separar ausencia de datos de falta de alcance. El backend debe devolver 403 o respuesta explicita; la interfaz no debe reemplazarlo por un estado vacio. El caso de OT de Terreno esta protegido por esta regla.

Regla de Midas

La sincronizacion consulta el catalogo oficial, agrega faltantes, conserva asignaciones, excluye CU377, audita cambios efectivos y es idempotente. No identifica la cuenta por un nombre ambiguo.

Fuentes de verdad consultadas

- `Controladores/prisma/schema.prisma`

- Controladores/pruebas
- Controladores/src/controladores/C_Finanzas.ts
- Controladores/src/rutas/finanzas.ts
- Vistas/src
- Vistas/src/App.tsx